

Cover

Implementing Initial Security Policies in Linux

8/10/26

By: Jason Man, Dominic Yeakel

Part 1

Part 1: Map Policy to Controls

1 & 2)

Policy line	Linux mechanism	Config file/command	Additional Details
12+ char passwords, complexity	pam_pwquality	/etc/security/pwquality.conf	Key settings: minlen=12, dcredit=-1 (require digit), ucredit=-1 (require uppercase), lcredit=-1 (require lowercase), ocredit=-1 (require special char), retry=3.
Lockout after 5 failed logins, 15 min	pam_faillock	/etc/security/faillock.conf	Key settings: deny=5, unlock_time=900 (seconds).
Log all auth attempts	auditd	/etc/audit/auditd.conf, /var/log/audit/audit.log	Query logs with ausearch -m USER_AUTH or aureport --auth.
Pre-login warning banner	SSH banner	/etc/issue.net, /etc/ssh/sshd_config	Requires Banner /etc/issue.net directive uncommented in sshd_config, then systemctl restart sshd.
No orphaned/default accounts	Manual account review	/etc/passwd	Commands: awk -F: '\$3>=1000{print \$1}' /etc/passwd, lastlog, chage -l <username>.
File integrity monitoring	AIDE	/var/lib/aide/aide.db	Baseline created with aide --init. Checks run via aide --check.

Policy line	Linux mechanism	Config file/command	Additional Details

3) Review the current account list and flag any accounts that violate the “no orphaned accounts” requirement

```
student@LinuxTargetVM:~$ pwd
/home/student
student@LinuxTargetVM:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
systemd-timesync:x:996:996:systemd Time Synchronization:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon,,,:/usr/lib/dhcpcd:/bin/false
messagebus:x:101:101::/nonexistent:/usr/sbin/nologin
syslog:x:102:102::/nonexistent:/usr/sbin/nologin
systemd-resolve:x:991:991:systemd Resolver:/:/usr/sbin/nologin
uidd:x:103:103::/run/uidd:/usr/sbin/nologin
tss:x:104:104:TPM software stack,,,:/var/lib/tpm:/bin/false
sshd:x:105:65534::/run/sshd:/usr/sbin/nologin
pollinate:x:106:1::/var/cache/pollinate:/bin/false
tcpdump:x:107:108::/nonexistent:/usr/sbin/nologin
landscape:x:108:109::/var/lib/landscape:/usr/sbin/nologin
fwupd-refresh:x:990:990:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
polkitd:x:989:989:User for polkitd:/:/usr/sbin/nologin
_chrony:x:109:113:Chrony daemon,,,:/var/lib/chrony:/usr/sbin/nologin
azureuser:x:1000:1000:Ubuntu:/home/azureuser:/bin/bash
student:x:1001:1001::/home/student:/bin/sh
oldservice:x:1002:1002::/home/oldservice:/bin/sh
logreview:x:1003:1003:logreview,,,:/home/logreview:/bin/bash
postfix:x:110:115::/var/spool/postfix:/usr/sbin/nologin
_aide:x:988:988:Advanced Intrusion Detection Environment:/var/lib/aide:/usr/sbin/nologin
```

Flagged Accounts:

azureuser:x:1000:1000:Ubuntu:/home/azureuser:/bin/bash

- Cloud provider default account, never logged into

```
student@LinuxTargetVM:~$ lastlog -u azureuser
Username      Port      From      Latest
azureuser          **Never logged in**
```

oldservice:x:1002:1002:./home/oldservice:/bin/sh

- Never logged into
- Has interactive /bin/sh shell but may be an abandoned account

```
student@LinuxTargetVM:~$ lastlog -u oldservice
Username      Port      From      Latest
oldservice          **Never logged in**
```

logreview:x:1003:1003:logreview,,,:/home/logreview:/bin/bash

- Never logged into
- Has interactive /bin/bash shell but may be an abandoned account

```
student@LinuxTargetVM:~$ lastlog -u logreview
Username      Port      From      Latest
logreview          **Never logged in**
```

Part 2

Part 2: Password and Account Lockout Policy

- 1) Install and configure `pam_pwquality` to require a minimum password length of 12 characters with complexity enforced

```
student@LinuxTargetVM:~$ pwd
/home/student
student@LinuxTargetVM:~$ sudo apt update
[sudo] password for student:
Sorry, try again.
[sudo] password for student:
Hit:1 http://azure.archive.ubuntu.com/ubuntu noble InRelease
Hit:2 http://azure.archive.ubuntu.com/ubuntu noble-updates InRelease
Hit:3 http://azure.archive.ubuntu.com/ubuntu noble-backports InRelease
Hit:4 http://azure.archive.ubuntu.com/ubuntu noble-security InRelease
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
14 packages can be upgraded. Run 'apt list --upgradable' to see them.
student@LinuxTargetVM:~$ sudo apt install libpam-pwquality -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
libpam-pwquality is already the newest version (1.4.5-3build1).
0 upgraded, 0 newly installed, 0 to remove and 14 not upgraded.
```

(Ran update and installed `libpam-pwquality`)

```
root@LinuxTargetVM:/home/student# sudo cp /etc/security/pwquality.conf /etc/security/pwquality.conf.bak
root@LinuxTargetVM:/home/student# sudo nano /etc/security/pwquality.conf
```

(Created backup)


```
# Configuration for systemwide password quality limits
# Defaults:
#
# Number of characters in the new password that must not be present in the
# old password.
# difok = 1
#
# Minimum acceptable size for the new password (plus one if
# credits are not disabled which is the default). (See pam_cracklib manual.)
# Cannot be set to lower value than 6.
minlen = 12
#
# The maximum credit for having digits in the new password. If less than 0
# it is the minimum number of digits in the new password.
# dcredit = 0
#
# The maximum credit for having uppercase characters in the new password.
# If less than 0 it is the minimum number of uppercase characters in the new
# password.
# ucredit = 0
#
# The maximum credit for having lowercase characters in the new password.
# If less than 0 it is the minimum number of lowercase characters in the new
# password.
# lcredit = 0
#
# The maximum credit for having other characters in the new password.
# If less than 0 it is the minimum number of other characters in the new
# password.
# ocredit = 0
#
# The minimum number of required classes of characters for the new
# password (digits, uppercase, lowercase, others).
minclass = 3
```

(Set minimum password length to 12 and minimum classes of characters to 3)

```
[root@LinuxTargetVM:/home/student# sudo nano /etc/security/pwquality.conf.bak
```

```

GNU nano 7.2 /etc/security/pwquality.conf.bak
# Configuration for systemwide password quality limits
# Defaults:
#
# Number of characters in the new password that must not be present in the
# old password.
# difok = 1
#
# Minimum acceptable size for the new password (plus one if
# credits are not disabled which is the default). (See pam_cracklib manual.)
# Cannot be set to lower value than 6.
minlen = 12
#
# The maximum credit for having digits in the new password. If less than 0
# it is the minimum number of digits in the new password.
# dcredit = 0
#
# The maximum credit for having uppercase characters in the new password.
# If less than 0 it is the minimum number of uppercase characters in the new
# password.
# ucredit = 0
#
# The maximum credit for having lowercase characters in the new password.
# If less than 0 it is the minimum number of lowercase characters in the new
# password.
# lcredit = 0
#
# The maximum credit for having other characters in the new password.
# If less than 0 it is the minimum number of other characters in the new
# password.
# ocredit = 0
#
# The minimum number of required classes of characters for the new
# password (digits, uppercase, lowercase, others).
minclass = 3
#
# The maximum number of allowed consecutive same characters in the new password.
# The check is disabled if the value is 0.
# maxrepeat = 0
#

```

(Changed backup file as well ^)

2. Configure pam_faillock (or pam_tally2, depending on distribution) to lock an account after 5 consecutive failed login attempts for at least 15 minutes.

```
root@LinuxTargetVM:/home/student# sudo cp /etc/security/faillock.conf /etc/security/faillock.conf.bak
root@LinuxTargetVM:/home/student# sudo nano /etc/security/faillock.conf
```

```
GNU nano 7.2 /etc/security/faillock.conf
# Configuration for locking the user after multiple failed
# authentication attempts.
#
# The directory where the user files with the failure records are kept.
# The default is /var/run/faillock.
# dir = /var/run/faillock
#
# Will log the user name into the system log if the user is not found.
# Enabled if option is present.
# audit
#
# Don't print informative messages.
# Enabled if option is present.
# silent
#
# Don't log informative messages via syslog.
# Enabled if option is present.
# no_log_info
#
# Only track failed user authentications attempts for local users
# in /etc/passwd and ignore centralized (AD, IdM, LDAP, etc.) users.
# The `faillock` command will also no longer track user failed
# authentication attempts. Enabling this option will prevent a
# double-lockout scenario where a user is locked out locally and
# in the centralized mechanism.
# Enabled if option is present.
# local_users_only
#
# Deny access if the number of consecutive authentication failures
# for this user during the recent interval exceeds n tries.
# The default is 3.
deny = 5
#
# The length of the interval during which the consecutive
# authentication failures must happen for the user account
# lock out is <replaceable>n</replaceable> seconds.
# The default is 900 (15 minutes).
# fail_interval = 900
#
# The access will be re-enabled after n seconds after the lock out.
# The value 0 has the same meaning as value `never` - the access
# will not be re-enabled without resetting the faillock
# entries by the `faillock` command.
# The default is 600 (10 minutes).
unlock_time = 900
```

(Set attempts to 5 before lockout and set lockout to 15 minutes)

```
GNU nano 7.2 /etc/security/faillock.conf.bak
# Configuration for locking the user after multiple failed
# authentication attempts.
#
# The directory where the user files with the failure records are kept.
# The default is /var/run/faillock.
# dir = /var/run/faillock
#
# Will log the user name into the system log if the user is not found.
# Enabled if option is present.
# audit
#
# Don't print informative messages.
# Enabled if option is present.
# silent
#
# Don't log informative messages via syslog.
# Enabled if option is present.
# no_log_info
#
# Only track failed user authentications attempts for local users
# in /etc/passwd and ignore centralized (AD, IdM, LDAP, etc.) users.
# The 'faillock' command will also no longer track user failed
# authentication attempts. Enabling this option will prevent a
# double-lockout scenario where a user is locked out locally and
# in the centralized mechanism.
# Enabled if option is present.
# local_users_only
#
# Deny access if the number of consecutive authentication failures
# for this user during the recent interval exceeds n tries.
# The default is 3.
deny = 5
#
# The length of the interval during which the consecutive
# authentication failures must happen for the user account
# lock out is <replaceable>n</replaceable> seconds.
# The default is 900 (15 minutes).
# fail_interval = 900
#
# The access will be re-enabled after n seconds after the lock out.
# The value 0 has the same meaning as value 'never' - the access
# will not be re-enabled without resetting the faillock
# entries by the 'faillock' command.
# The default is 600 (10 minutes).
unlock_time = 900
```

(Changed backup file as well ^)

```
student@LinuxTargetVM:~$ sudo nano /etc/pam.d/common-auth
```

```
GNU nano 7.2 /etc/pam.d/common-a
#
# /etc/pam.d/common-auth - authentication settings common to all services
#
# This file is included from other service-specific PAM config files,
# and should contain a list of the authentication modules that define
# the central authentication scheme for use on the system
# (e.g., /etc/shadow, LDAP, Kerberos, etc.). The default is to use the
# traditional Unix authentication mechanisms.
#
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules. See
# pam-auth-update(8) for details.

# here are the per-package modules (the "Primary" block)
#auth [success=1 default=ignore] pam_unix.so nullok
# here's the fallback if no module succeeds
#auth requisite pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
#auth required pam_permit.so
# and here are more per-package modules (the "Additional" block)
#auth optional pam_cap.so
auth required pam_faillock.so preauth
auth [success=1 default=ignore] pam_unix.so
auth [default=die] pam_faillock.so authfail
auth sufficient pam_faillock.so authsucc
# end of pam-auth-update config
```

```
student@LinuxTargetVM:~$ sudo nano /etc/pam.d/common-account
```

```
GNU nano 7.2 /etc/pam.d/common-account *
#
# /etc/pam.d/common-account - authorization settings common to all services
#
# This file is included from other service-specific PAM config files,
# and should contain a list of the authorization modules that define
# the central access policy for use on the system. The default is to
# only deny service to users whose accounts are expired in /etc/shadow.
#
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules. See
# pam-auth-update(8) for details.
#
# here are the per-package modules (the "Primary" block)
account required pam_faillock.so
account [success=1 new_authtok_reqd=done default=ignore] pam_unix.so
# here's the fallback if no module succeeds
account requisite pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
account required pam_permit.so
# and here are more per-package modules (the "Additional" block)
# end of pam-auth-update config
```

3. Test your lockout policy with a series of deliberately failed logins on a test account, and confirm the account locks as expected.

```
PS C:\Users\Dayea> ssh student@52.249.216.214
# This system is the property of Meridian Trust Bank. Unauthorized access is prohibited.
# All activity on this system may be monitored, recorded, and disclosed to authorized parties
student@52.249.216.214's password:
Permission denied, please try again.
student@52.249.216.214's password:
Permission denied, please try again.
student@52.249.216.214's password:
student@52.249.216.214: Permission denied (publickey,password).
PS C:\Users\Dayea> ssh student@52.249.216.214
# This system is the property of Meridian Trust Bank. Unauthorized access is prohibited.
# All activity on this system may be monitored, recorded, and disclosed to authorized parties
student@52.249.216.214's password:
Permission denied, please try again.
student@52.249.216.214's password:
Permission denied, please try again.
student@52.249.216.214's password:
ssh_dispatch_run_fatal: Connection to 52.249.216.214 port 22: Connection timed out
```

```
root@LinuxTargetVM:/home/student# sudo faillock --user student
```

```
student:
When                Type Source                                Valid
2026-08-11 13:34:36 RHOST 24.229.178.141                      V
2026-08-11 13:34:40 RHOST 24.229.178.141                      V
2026-08-11 13:34:43 RHOST 24.229.178.141                      V
2026-08-11 13:34:50 RHOST 24.229.178.141                      V
2026-08-11 13:34:53 RHOST 24.229.178.141                      V
```

4. Document the exact configuration lines you added or changed.

- faillock.conf + backup
 - deny = 5
 - unlock_time = 900
- pwquality.conf + backup
 - minlen = 12
 - minclass = 3

Part 3

Part 3: Audit Logging and Legal Banner

- 1) Install and enable auditd, and confirm authentication events are being captured in the audit log.

```
student@LinuxTargetVM:~$ sudo apt install auditd audispd-plugins -y
[sudo] password for student:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
auditd is already the newest version (1:3.1.2-2.1build1.1).
The following NEW packages will be installed:
  audispd-plugins
0 upgraded, 1 newly installed, 0 to remove and 14 not upgraded.
Need to get 38.8 kB of archives.
After this operation, 131 kB of additional disk space will be used.
Get:1 http://azure.archive.ubuntu.com/ubuntu noble-updates/universe amd64 audispd-plugins amd64 1:3.1.2-2.1build1.1 [38.8 kB]
Fetched 38.8 kB in 0s (888 kB/s)
Selecting previously unselected package audispd-plugins.
(Reading database ... 99235 files and directories currently installed.)
Preparing to unpack .../audispd-plugins_1%3a3.1.2-2.1build1.1_amd64.deb ...
Unpacking audispd-plugins (1:3.1.2-2.1build1.1) ...
Setting up audispd-plugins (1:3.1.2-2.1build1.1) ...
Processing triggers for man-db (2.12.0-4build2) ...
Scanning processes...
Scanning linux images...

Pending kernel upgrade!
Running kernel version:
  6.17.0-1021-azure
Diagnostics:
  The currently running kernel version is not the expected kernel version 6.17.0-1022-azure.

Restarting the system to load the new kernel will not be handled automatically, so you should consider
rebooting.

No services need to be restarted.

No containers need to be restarted.

No user sessions are running outdated binaries.

No VM guests are running outdated hypervisor (qemu) binaries on this host

student@LinuxTargetVM:~$ sudo systemctl enable auditd --now
Synchronizing state of auditd.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable auditd
```

(Installed and enabled the auditd service)

```
student@LinuxTargetVM:~$ sudo systemctl status auditd
● auditd.service - Security Auditing Service
   Loaded: loaded (/usr/lib/systemd/system/auditd.service; enabled; preset: enabled)
   Active: active (running) since Mon 2026-08-10 18:17:30 UTC; 2h 33min ago
     Docs: man:auditd(8)
           https://github.com/linux-audit/audit-documentation
  Main PID: 86771 (auditd)
    Tasks: 2 (limit: 9432)
   Memory: 820.0K (peak: 2.4M)
      CPU: 146ms
   CGroup: /system.slice/auditd.service
           └─86771 /sbin/auditd

Aug 10 18:17:30 LinuxTargetVM augenrules[86785]: enabled 1
Aug 10 18:17:30 LinuxTargetVM augenrules[86785]: failure 1
Aug 10 18:17:30 LinuxTargetVM augenrules[86785]: pid 86771
Aug 10 18:17:30 LinuxTargetVM augenrules[86785]: rate_limit 0
Aug 10 18:17:30 LinuxTargetVM augenrules[86785]: backlog_limit 8192
Aug 10 18:17:30 LinuxTargetVM augenrules[86785]: lost 0
Aug 10 18:17:30 LinuxTargetVM augenrules[86785]: backlog 0
Aug 10 18:17:30 LinuxTargetVM augenrules[86785]: backlog_wait_time 60000
Aug 10 18:17:30 LinuxTargetVM augenrules[86785]: backlog_wait_time_actual 0
Aug 10 18:17:30 LinuxTargetVM systemd[1]: Started auditd.service - Security Auditing Service.
```

(Check the status of the service)

```

student@LinuxTargetVM:~$ sudo ausearch -m USER_LOGIN -ts recent
time-->Mon Aug 10 20:44:00 2026
type=USER_LOGIN msg=audit(1786394640.003:1069): pid=108900 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=45.148.10.151 terminal=sshd res=failed'
time-->Mon Aug 10 20:44:03 2026
type=USER_LOGIN msg=audit(1786394643.279:1071): pid=108900 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=45.148.10.151 terminal=sshd res=failed'
time-->Mon Aug 10 20:44:06 2026
type=USER_LOGIN msg=audit(1786394646.023:1073): pid=108900 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=45.148.10.151 terminal=sshd res=failed'
time-->Mon Aug 10 20:44:09 2026
type=USER_LOGIN msg=audit(1786394649.631:1076): pid=108900 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=45.148.10.151 terminal=sshd res=failed'
time-->Mon Aug 10 20:44:12 2026
type=USER_LOGIN msg=audit(1786394652.239:1078): pid=108900 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=45.148.10.151 terminal=sshd res=failed'
time-->Mon Aug 10 20:45:32 2026
type=USER_LOGIN msg=audit(1786394732.887:1088): pid=108913 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=41.74.91.200 terminal=sshd res=failed'
time-->Mon Aug 10 20:46:08 2026
type=USER_LOGIN msg=audit(1786394768.354:1090): pid=108915 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=64.235.58.29 terminal=sshd res=failed'
time-->Mon Aug 10 20:51:31 2026
type=USER_LOGIN msg=audit(1786395091.247:1204): pid=109273 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=45.148.10.147 terminal=sshd res=failed'
time-->Mon Aug 10 20:51:34 2026
type=USER_LOGIN msg=audit(1786395094.523:1206): pid=109273 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=45.148.10.147 terminal=sshd res=failed'
time-->Mon Aug 10 20:51:37 2026
type=USER_LOGIN msg=audit(1786395097.798:1209): pid=109273 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=45.148.10.147 terminal=sshd res=failed'
time-->Mon Aug 10 20:51:40 2026
type=USER_LOGIN msg=audit(1786395100.875:1211): pid=109273 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=45.148.10.147 terminal=sshd res=failed'
time-->Mon Aug 10 20:51:44 2026
type=USER_LOGIN msg=audit(1786395104.818:1213): pid=109273 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=45.148.10.147 terminal=sshd res=failed'
time-->Mon Aug 10 20:51:58 2026
type=USER_LOGIN msg=audit(1786395118.551:1216): pid=109279 uid=0 auid=4294967295 ses=4294967295 subj=unconfined m
sg='op=login acct="root" exe="/usr/sbin/sshd" hostname=? addr=64.235.58.29 terminal=sshd res=failed'
time-->Mon Aug 10 20:52:33 2026
type=USER_LOGIN msg=audit(1786395153.160:1223): pid=109284 uid=0 auid=1001 ses=957 subj=unconfined msg='op=login
id=1001 exe="/usr/sbin/sshd" hostname=67.172.63.253 addr=67.172.63.253 terminal=/dev/pts/1 res=success'

```

(Shows all recent logins)

- 2) Configure /etc/issue.net with an authorized-use warning banner, and update sshd_config to display it before login (Banner /etc/issue.net)

```

student@LinuxTargetVM:~$ sudo cp /etc/issue.net /etc/issue.net.bak
student@LinuxTargetVM:~$ sudo nano /etc/issue.net
student@LinuxTargetVM:~$ cat /etc/issue.net
# This system is the property of Meridian Trust Bank. Unauthorized access is prohibited.
# All activity on this system may be monitored, recorded, and disclosed to authorized parties

```

(Added banner through nano in /etc/issue.net)

```
student@LinuxTargetVM:~$ sudo cp /etc/ssh/sshd_config /etc/ssh/sshd_config.bak
student@LinuxTargetVM:~$ sudo nano /etc/ssh/sshd_config
student@LinuxTargetVM:~$ cat /etc/ssh/sshd_config
cat: /etc/ssh/sshd_config: Permission denied
student@LinuxTargetVM:~$ sudo cat /etc/ssh/sshd_config
Banner /etc/issue.net
```

(Added “Banner /etc/[issue.net](https://www.issue.net)” to /etc/ssh/sshd_config through nano to call on the file when attempting to SSH)

- 3) Restart the SSH service and verify the banner appears before you’re prompted for credentials

```
student@LinuxTargetVM:~$ sudo systemctl restart ssh
```

```
PS C:\Users\Dayea> ssh student@52.249.216.214
# This system is the property of Meridian Trust Bank. Unauthorized access is prohibited.
# All activity on this system may be monitored, recorded, and disclosed to authorized parties
student@52.249.216.214's password:
```

Part 4

Part 4: File Integrity Baseline

1. Install AIDE and initialize its database against the current state of the system.

```
student@LinuxTargetVM:~$ sudo apt install aide aide-common -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
aide is already the newest version (0.18.6-2ubuntu0.1).
aide-common is already the newest version (0.18.6-2ubuntu0.1).
aide-common set to manually installed.
0 upgraded, 0 newly installed, 0 to remove and 14 not upgraded.
```

```
student@LinuxTargetVM:~$ sudo aideinit
Running aide --init...
```

(Installed and initialized AIDE)

```
student@LinuxTargetVM:~$ sudo cp /var/lib/aide/aide.db.new /var/lib/aide/aide.db
```

(Initializing create the .new file, now we copy and paste it into the .db file that AIDE compares against)

2. Make a small deliberate unauthorized-looking change to a file under /etc (e.g., append a line to a config file).

```
student@LinuxTargetVM:~$ sudo bash -c 'echo "#test change for AIDE" >> /etc/hosts'
```

3. Run an AIDE check and confirm it flags the change you made.

```
student@LinuxTargetVM:~$ sudo aide --config /etc/aide/aide.conf --check
```

Detailed information about changes:

```
File: /etc/hosts
Size      : 221 | 243
Mtime     : 2026-08-01 22:40:55 +0000 | 2026-08-10 21:08:42 +0000
Ctime     : 2026-08-02 04:18:54 +0000 | 2026-08-10 21:08:42 +0000
MD5       : FGNQjyjttNbVrjSbIOAECQ= | v4pM904KWGZPzc1pWMHS4Q=
SHA1      : p3e+UcecYH7dYcjhLnm3dd3IpsY= | bCLWi/xjEalQgK/vW9z5kt4RmAo=
SHA256    : qk6pIuTyoSd7WqyJj1rz3EovMBITw3KQ | yg3o61LTFBa0bkkrrVIWLuFZf6ktoEn6
           : UG5q3XnYnBE= | WsWgL0LOkpI=
SHA512    : 18rnM4Y3FN2PmLd0aZJatTxWU7ir6+Ca | sgrdhRxVvM+9JQRuBwcptTBrMUh0Jm8w
           : DXAaZ7hMW/gKPK4RtHE6LvaI/fu0cM8X | 3m3AV9dZLYsWsDlVqdCHU+k//R19i1uk
           : idptG0eZN7y/MnrN4armrA= | hXTxc40PWZV24rjYdJC7Ww=
RMD160    : BK61das4ng0zxoKXNNGWT3CbdQ= | gWGPzWJ5dqWV6DwW78I3IboVNSM=
TIGER     : 0jxvBhjFVPncQmmeF+DzSmKPrVSBkqfu | pJ2BqSWUEE+zHlEpMNAz17FLaz133/2j
CRC32     : 1R2wUQ= | Y7ugCA=
CRC32B    : 8kgghw= | JZkXCA=
HAVAL     : udTixcfB3dxTXgNepbYvSz/RxyrU86Np | 7j68R0E4SWe+w7959ATTvok/RaTAfgza
           : J7Kb0le1H/I= | 2WTNIo7WLuE=
WHIRLPOOL : 8eVuYHryNmx7gyPhZ2dgAKgFOCL9onMn | zXK3nYT9j70zvdcpKbJDHg1lRyrKLIRM
           : IHxmS9stn804YyGJsFINlP2MTYxo2DhG | oMjNAQEPGVW6d337GAgeBjbvdDcLEa7U
           : 2C3NxbUZ3nXKnHRqou+/0A= | d6+NIsh9wTVneE5WQsAcJA=
GOST      : 4R9BCTRYuPMVCMwVmdkuufyWhpBVd//C | o0jbdqwZdbbE+aPLF4e9W4W9a1Kwtd+E
           : bL6fgtx1m14= | 4sUr9BThCaQ=
```

- /etc/hosts has been modified

4. Revert your test change and re-run the check to confirm a clean result.

```
student@LinuxTargetVM:~$ sudo sed -i '$ d' /etc/hosts
```

Detailed information about changes:

```
File: /etc/hosts
Mtime     : 2026-08-01 22:40:55 +0000 | 2026-08-10 21:26:50 +0000
Ctime     : 2026-08-02 04:18:54 +0000 | 2026-08-10 21:26:50 +0000
Inode     : 106 | 34534
```

Part 5

Part 5: Build a Compliance-Check Script

1. Write a single Bash script (compliance_check.sh) that checks the host against the policy and prints a clear PASS or FAIL for each item. At minimum, it should check:

- That the configured minimum password length meets policy
- That account lockout is configured with the correct threshold
- That auditd is installed and running
- That the SSH login banner is configured
- That AIDE is installed and has an initialized database

```
[root@LinuxTargetVM:/home/student# pwd
/home/student
root@LinuxTargetVM:/home/student# nano compliance_check.sh
```

```
GNU nano 7.2 compliance_check.sh
#!/bin/bash

echo "Meridian Trust Bank - Linux Compliance Check"

MINLEN=$(grep -E "^minlen" /etc/security/pwquality.conf | awk -F= '{print $2}' | tr -d ' ')
if [ "$MINLEN" -ge 12 ] 2>/dev/null; then
    echo "[PASS] Minimum password length is $MINLEN (policy requires 12+)"
else
    echo "[FAIL] Minimum password length is not set to 12 or higher"
fi

DENY=$(grep -E "^deny" /etc/security/faillock.conf | awk -F= '{print $2}' | tr -d ' ')
if [ "$DENY" -le 5 ] 2>/dev/null && [ "$DENY" -ge 1 ] 2>/dev/null; then
    echo "[PASS] Account lockout threshold is $DENY (policy requires 5 or fewer)"
else
    echo "[FAIL] Account lockout threshold is not configured correctly"
fi

if systemctl is-active --quiet auditd; then
    echo "[PASS] auditd is installed and running"
else
    echo "[FAIL] auditd is not running"
fi

if grep -q "^Banner /etc/issue.net" /etc/ssh/sshd_config; then
    echo "[PASS] SSH login banner is configured"
else
    echo "[FAIL] SSH login banner is not configured"
fi
```

```

fi
if dpkg -l | grep -q "^ii  aide" && [ -f /var/lib/aide/aide.db ]; then
    echo "[PASS] AIDE is installed with an initialized database"
else
    echo "[FAIL] AIDE is not installed or has no database"
fi
echo "Check complete"

```

(Script testing policies)

2. Run your finished script and capture its output as evidence.

```

root@LinuxTargetVM:/home/student# chmod +x compliance_check.sh
root@LinuxTargetVM:/home/student# ./compliance_check.sh
Meridian Trust Bank – Linux Compliance Check
[PASS] Minimum password length is 12 (policy requires 12+)
[PASS] Account lockout threshold is 5 (policy requires 5 or fewer)
[PASS] auditd is installed and running
[PASS] SSH login banner is configured
[PASS] AIDE is installed with an initialized database
Check complete

```

- All policies passed

3. Fix anything your own script flags as a FAIL before submitting.

- a. Output did not list anything that failed

Reflection Questions

Reflection Questions

1. Which policy line was hardest to translate into a technical control, and why?

The password lockout after 5 attempts was the hardest just because we thought the ssh login should've prompted us 5 times instead of 3. Meanwhile, the whole time it was counting in the backend and we had to attempt login 2 more times after the first set of login attempts to see the results.

2. Why does a written policy matter even though the technical controls are what actually enforce it? What could go wrong with controls but no documented policy, or a policy with no enforced controls?

Written policy is necessary along with technical controls because it acts as a guide and log for them. It describes clear intent for why the technical controls are there in the first place. Without written policy, security teams have no organized way of explaining their security decisions and there is no documentation to audit against.

3. How does your compliance script change the way this host gets verified in the future compared to a one-time manual check?

The `compliance_check.sh` script changes the way the host gets verified by automating the auditing process. While a manual check can be slow and prone to human error, a script can instantly check if a system is compliant and with greater accuracy.